

PCI DSS Compliance Technical Support & Sustainment (AF Installations) Questions and Answers 19 March 2026

#	Questions	Answers w/ SOO Para. Reference
1	Point of clarification for 1.5.1.2 - will installations without local IT support require the vendor provide any additional vulnerability scanning and management capabilities? We noted the previous response that the request is to provide the critical oversight, analysis, remediation guidance and hands-on technical support to manage the vulnerability lifecycle, not on operating the testing tools themselves.	No additional vulnerability scanning and management capabilities are required. While tool provision is out of scope (SOO 1.5.2), the contractor is responsible for the technical support for ongoing vulnerability management, including monitoring, lifecycle management and remediation guidance, and hands-on support as required by installations, both remote and onsite as needed (SOO 1.5.1.2, 4.1.3.1.1).
2	Is AFSVC open to a fully vendor-managed model for remote security operations (SOC, SIEM)?	No. The SOO outlines a collaborative model to empower local staff, not a fully vendor-managed operation. Your role is to augment, not replace, local personnel (SOO 1.3.1, 2.2.3).
3	To what degree is in-person / hands-on support expected, and for what geographic areas? Would a proposed solution for quarterly travel be acceptable, or is the vendor expected to provide permanent local staff to support installations?	On-site and remote assistance is required (SOO 3.1). Expect hands-on support at ~20-30 of 104 locations (SOO 1.4, 1.5.1.2). Travel is as-needed for physical audits and audit preparedness; permanent local staff are not required (SOO 6.4.2).
4	What level of security clearance is expected for vendor personnel? Will all vendor staff engaged in supporting AFSVC require a Tier 1? Will any vendor staff require a Tier 3?	Tier 1 is sufficient, most of the work is unclassified (SOO 6.6.1). Refer to SOO 6.7.2.2, Contractor personnel shall not be assigned to perform duties within IAT-II or IAT-III, and or requiring "Limited Privileged Access" such as system or database administration rights, to any NAFI application or network.
5	Will vendor interact with any CUI / does the proposed solution require a CMMC certification?	Yes, the vendor will handle CUI and require training per SOO 6.6.3. Refer to SOO 3.2 Contractor Qualifications.
6	Are all assets centrally managed (e.g., centralized patching tools, endpoint management, configuration management)?If not, identify unmanaged or partially managed assets.	The objective is to achieve a "proactive, centrally-governed security posture" (SOO 1.3.1), which indicates assets are not currently all centrally managed. The SOO notes that "critical gaps in security tools and on-site technical support prevent a proactive, centrally managed defense" (SOO 1.2.1).
7	Are legacy or end of life systems present? If yes, list known unsupported software or systems and any business constraints.	Any in-scope legacy or end of life systems will be upgraded by August 2026. Many are scoped out using P2PE terminals.
8	Are externally facing assets included in scope?(Web servers, VPNs, firewalls, cloud services, etc.)	External assets are out of scope of this SOO, penetration testing is being conducted, per SOO 1.5.2. <i>The SOO requires expertise with firewalls, VPNs (SOO 3.2.1.4), and cloud platforms like AWS, Azure, and GCP (SOO 3.2.1.9).</i>
9	Is there any preference for fee arrangements - per endpoint, hourly, fixed fee, etc.	The contract will be fixed fee, based on deliverables (SOO 3.1). See Contract Admin Data, Paragraph 4.
10	Will any cloud workloads be in-scope? Do you utilize any cloud service providers (e.g., AWS, Azure, GCP) for any part of your payment processing environment?	Yes, some Aloha Cloud is in CDE scope. Required expertise in AWS, Azure, and GCP, and the directive to prioritize cloud-based tools, confirm cloud workloads are in scope (SOO 3.2.1.9, 4.1.1.3).
11	Many installations have successfully achieved PCI compliance using validated P2PE solutions, hosted payment pages, or centralized enterprise payment gateways. Has AFSVC evaluated whether standardizing one or more of these proven, lower-scope approaches—where appropriate—could enhance consistency across installations while reducing lifecycle costs and simplifying compliance sustainment, as an alternative to deploying and maintaining separate tool suites at each location?	Standardization is underway, as AFSVC has moved from a decentralized to centralized approach. An enterprise Tool suite solution, where applicable, is being requested in this SOO (4.1.1).
12	The SOO currently directs the contractor to recommend and implement a "complete enterprise tool suite" (SIEM, DLP, MFA, etc.) and to prioritize "modern, automated, and cloud-based tools." As a full-service QSA with experience delivering thousands of services to similar environments outlined in both the original and current SOO we find that the scope in the first SOO to more cost effective and timely. Would AFSVC consider modifying the requirement to include, as part of Phase 1, a QSA-performed assessment that delivers a validated scope-reduction roadmap and presents multiple compliant implementation approaches—including both tool-enabled and scope-optimized models—along with a side-by-side 3–5 year total cost of ownership analysis to support AFSVC decision making?	The SOO requires the contractor to conduct a "Gap Analysis" and deliver a "Solution Implementation Strategy" for a "complete enterprise tool suite" (SOO 4.1.1.1, 4.1.1.4). The contractor's role is to provide technical support, not to perform a QSA function, although collaboration with a QSA vendor is expected (SOO 4.1.3.2.2).
13	The SOO emphasizes on-site technical support, 24/7 monitoring, ongoing tool management, and sustainment across up to 30 installations. Has AFSVC conducted, or would it consider conducting, a comparative analysis of total lifecycle cost—including personnel, licensing, maintenance, training, and option years—across alternative compliant approaches, such as tool-intensive implementations versus scope reduction and process simplification, which for many federal and DoD organizations has historically reduced compliance effort by 70–90%, to ensure long-term operational sustainability and resource alignment?	The SOO establishes the requirement to deploy and manage a standardized tool suite (SOO 1.5.1). A comparative cost analysis of alternative compliance approaches is not a specified deliverable within the SOO. The contractor is expected to provide a detailed cost analysis for the recommended tools as part of the implementation strategy (SOO 4.1.1.4.2). A P2PE based scope reduction strategy is in place, while certain components remain within full PCI scope. Supporting data and documentation will be provided upon contract award.
14	The SOO states that the AFSVC intends to award all phases to a single vendor but that Phases 2 and 4 are at the AFSVC's discretion based on Phase 1 results. Would AFSVC consider adding language to allow the Phase 1 contractor to recommend and potentially execute a QSA-led scope-reduction strategy, as well as evaluate multiple compliant execution paths, so the AFSVC can select the approach that best aligns with cost, risk tolerance, and sustainment objectives—potentially eliminating the need for Phases 2 and 4—prior to proceeding to subsequent phases?	The Government is currently engaged with a QSA firm; however, the expectation is that you will collaborate to develop and execute a forward-looking strategy.
15	DoD cybersecurity guidance (e.g., Zero Trust principles, Cloud Security Playbook elements, and integration with existing DISN/DoDIN frameworks) emphasizes risk-based, least-privilege controls over broad tooling deployment. How does the SOO's focus on implementing and managing a full suite of security tools (SIEM, DLP, MFA across CDEs) align with these mandates, and would the AFSVC be open to requiring Phase 1 recommendations to demonstrate compatibility with DoD-wide security architectures to avoid redundant or conflicting implementations?	Refer to SOO 1.2 Background and 1.3 Objective. As part of the Phase 1: Gap Analysis and Remediation (SOO 4.1.1), AFSVC is requesting a strategy and recommendation for the required security tools and services to comply with PCI DSS (SOO 4.1.1.3 and 4.1.1.4). The solution must align with DoD standards, including NIST SP 800-53, CISA directives, and the DoD RMF (SOO 6.9.2) while closing PCI control gaps and avoiding redundancy. For further clarification, the DAF NAFIs process payment card transactions over locally managed commercial networks rather than the NIPRNet.
16	PCI DSS best practices for sustainment emphasize repeatable, low-effort processes over complex tooling. Has the AFSVC evaluated whether the proposed enterprise tool suite—including licensing, configuration, monitoring, and update requirements—aligns with sustainable compliance models observed in other federal environments, and would AFSVC consider incorporating long-term sustainment factors, such as operational complexity, maintenance demands, and staffing dependencies, into Phase 1 deliverables to support stable and durable compliance outcomes?"	A PCI DSS compliant recommendation is part of SOO 4.1.1, Phase 1: Gap Analysis and Remediation
17	Should the Contractor plan for steady-state operations only, or include surge support for assessment cycles, remediation efforts, or incident response events?	The contractor must plan for both. The SOO requires "Ongoing Technical Support" (SOO 4.1.3), including "24/7 Support Services" (SOO 4.1.3.1.3), "Tier 2/3 Sustainment Support" for escalations (SOO 2.2.5), incident response assistance (SOO 4.1.3.4.2.4), and "PCI DSS Assessment Preparation Support" (SOO 4.1.3.2).
18	Are clearance requirements (e.g., Public Trust, Secret) required at contract start, and will the Government sponsor clearances if needed?	All clearances will be sponsored by the Govt once the Contract is awarded. See SOO Para 6.7. To ensure all Personnel needing background checks meet the requirements.
19	What are the expected incident response roles and responsibilities for the Contractor (e.g., triage, escalation, remediation support), and how will these integrate with Government teams?	The contractor is responsible for "hands-on technical support for ongoing...incident response" (SOO 1.5.1.2) and must have experience with "containment, eradication, and recovery" (SOO 3.2.1.3). Suspected incidents must
20	Are there minimum staffing levels, labor categories, or experience thresholds that the Government will use to determine technical acceptability?	AFSVC is seeking industry to provide this answer.
21	Is a Facility Clearance (FCL) required at time of proposal or award, and if so, will the Government sponsor the prime or subcontractor for FCL?	All clearances will be sponsored by the Govt once the Contract is awarded. See SOO Para 6.7. To ensure all Personnel needing background checks meet the requirements.
22	Through which channels do you accept payments (e.g., E-commerce, Card-Present/Retail, or Mail Order/Telephone Order)?	CDE scoping and inventory documentation will be provided upon contract award. Refer to SOO 4.1.
23	Approximately how many credit/debit card transactions do you process annually across all channels?	Over 13 million annual payment card transactions (SOO 1.4).
24	Are you operating as a Merchant (taking payments for your own goods/services), a Service Provider (processing on behalf of others), or both?	AFSVC is a Merchant (SOO 1.1.1).
25	Does your organization store, process, or transmit Primary Account Numbers (PAN) in any electronic format?	Yes. The purpose of this SOO is to ensure full security of the CDE (SOO 1.1.1, 1.3.1).
26	Do you store any Sensitive Authentication Data (SAD) after authorization (e.g., CVV, CID, or PIN data)?	No. Sensitive Authentication Data (SAD) is not stored.
27	For E-commerce, do you use a third-party redirect (like a hosted payment page), an iFrame, or do you capture the data directly on your own servers?	Hosted payment pages are used for individual activity ecommerce solutions; an enterprise eCommerce solution is in development.
28	Is your Cardholder Data Environment (CDE) currently segmented from the rest of your corporate network, or is the entire network in scope?	The CDE is segmented.
29	Do any third-party vendors or partners have remote access to your internal network or the CDE?	Yes.
30	Do you use physical Point of Sale (POS) terminals or hardware security modules (HSM)? If so, are they PCI-validated?	Physical POS are in use and in the process of full PCI-validation.
31	If you take orders over the phone (MOTO), are calls recorded, and if so, is card data being captured in those recordings?	Calls are not recorded in the case of phone orders.
32	Can you provide a list of all third parties that could impact the security of your cardholder data (e.g., web hosting, data centers, managed firewall providers)?	Third party details can be delivered upon contract award.
33	Do you have an up-to-date network diagram and data flow diagram that specifically identifies all cardholder data flows?	We do have an up-to-date standardized network diagram.
34	Is your IT or security infrastructure managed in-house, or is it outsourced to a Managed Service Provider (MSP)?	The SOO implies a mixed environment. This contract is required due to a lack of specialized on-site IT support at many locations (SOO 2.0).
35	What was your most recent PCI DSS validation level (e.g., SAQ A, SAQ D, or Level 1 ROC), and when was it last completed?	AFSVC NAFI is a Level 1 Merchant and is currently undergoing a SAQ-D assessment with a QSA firm. Specific assessment results are considered sensitive and are not disclosed publicly.
36	What kind of service you are looking for? A GAP, Advisory, or a final assessment?	See SOO.

37	For these 104 locations, what kind of locations do we have? Are these data centers, stores? Is required clearance to access these locations? If yes, which constrains are required?	The locations are DAF NAFI enterprise Services programs, including food, fitness, childcare, lodging, and recreation (SOO 1.1.1). Clearance requirements are determined by DAF, and the Government will sponsor them (SOO 6.7). Part 2 Question. All clearances will be sponsored by the Govt once the Contract is awarded. See SOO Para 6.7. To ensure all Personnel needing background checks meet the requirements. Part 2 Question. All clearances will be sponsored by the Govt once the Contract is awarded. See SOO Para 6.7. To ensure all Personnel needing background checks meet the requirements.
38	Do you already have PCI policies and procedures in place?	Yes, PCI policies are in place with procedures in place at the majority of installations. Refer to SOO 1.4 Volumetrics and 1.5 Scope.
39	The target initial completion date is August 2026. Are there any incentives or evaluation benefits for completing the work ahead of schedule?	No, there are no incentives and the August date is strictly related to SOO Para 4.1.1.4.3: A high-level implementation plan that defines the necessary steps, resource requirements, and a project timeline with a target initial completion date of August 2026.
40	Is the use of non-US persons acceptable for OCONUS locations?	No; Non-US Persons are NOT acceptable for OCONUS locations. Greencard Holders must be holders for three years.
41	The Instructions to Contractors document states "Contractor will propose unit prices for each Contract Line Item (CLIN) - IAW Suppliers, Services and Prices of this solicitation". Can the Government provide a list of CLINs and descriptions?	Yes, a list of CLINS and descriptions will be provided in the RFQ.
42	Could you please clarify whether the March 13 SOO – PCI Compliance Technical Support & Sustainment is intended to replace the January PCI DSS Audit Readiness SOO, or if both SOOs are separate and intended to work together?	It does NOT replace it. The requirements are separate. The Audit is separate from PCI Compliance Technical Support & Sustainment.